

LETSDEFEND · SOC ANALYST INVESTIGATION

INCIDENT RESPONSE REPORT

SOC166 — Javascript Code Detected in Requested URL

Analyst: Mehenni May · Date: 26 February 2022 · Classification: TLP:WHITE · Platform: LetsDefend

VERDICT CONFIRMED MALICIOUS	SEVERITY MEDIUM	ATTACK TYPE XSS / WEB ATTACK	STATUS INVESTIGATION COMPLETE
---	---------------------------	--	---

01 EXECUTIVE SUMMARY

This report documents the analysis of a Reflected Cross-Site Scripting (XSS) attack against internal web server WebServer1002 on the LetsDefend SOC platform. The attacker, originating from external IP 112.85.42.13, injected a JavaScript payload via the search URL parameter. The server returned HTTP 200 with a 1024-byte response confirming the attack was successful. The host was subsequently contained via Endpoint Security.

Category	Summary
What happened	An external attacker from IP 112.85.42.13 (APNIC — Asia Pacific) sent a crafted GET request with a Reflected XSS payload to internal web server WebServer1002 (172.16.17.17) on port 443. The payload was injected via the q= search parameter using a <script> tag attempting javascript:alert(1) execution.
Why it matters	The server returned HTTP 200 with a 1024-byte response body, confirming the payload was reflected back to the client. In a Reflected XSS scenario this means the injected script executes in any victim browser loading the URL.
Attack vector	Internet to Company Network. Source IP 112.85.42.13 has no reverse DNS, no MX records (MXToolbox), and no domain association (WHOIS). The attack was a direct web request with no phishing or email delivery component.
Business impact	Successful Reflected XSS enables session token theft, credential harvesting, browser exploitation, and redirection to attacker-controlled infrastructure for any authenticated user who visits the compromised endpoint.
What was done	Log analysis confirmed HTTP 200 + 1024-byte response. Source IP intelligence gathered via WHOIS and MXToolbox. Traffic direction assessed. Full SOC playbook executed. Host WebServer1002 contained via Endpoint Security module.
Recommended actions	Implement input validation and output encoding on the search endpoint. Deploy Content Security Policy (CSP) headers. Block 112.85.42.13 at the perimeter firewall. Conduct a full DAST audit on WebServer1002 before releasing from containment.

02 ALERT & EVENT DETAILS

2.1 Alert Summary

Event ID	116
----------	-----

Alert Rule	SOC166 — Javascript Code Detected in Requested URL
Severity	Medium
Level	Security Analyst
Event Time	Feb 26, 2022, 06:56 PM
Hostname	WebServer1002
Alert Trigger	Javascript code detected in URL
Device Action	Allowed
Verdict	TRUE POSITIVE — XSS Attack Confirmed

Medium	Feb, 26, 2022, 06:56 PM	SOC166 - Javascript Code Detected in Requested URL	116	Web Attack	>> ✓
EventID :	116				
Event Time :	Feb, 26, 2022, 06:56 PM				
Rule :	SOC166 - Javascript Code Detected in Requested URL				
Level :	Security Analyst				
Hostname :	WebServer1002				
Destination IP Address :	172.16.17.17				
Source IP Address :	112.85.42.13				
HTTP Request Method :	GET				
Requested URL :	https://172.16.17.17/search/?q=<\$script>javascript:\$alert(1)<\$/script>				
User-Agent :	Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1				
Alert Trigger Reason :	Javascript code detected in URL				
Device Action :	Allowed				
Show Hint	🔗				

Figure 1 — SOC166 Alert Overview: JavaScript Code Detected in Requested URL

The alert was triggered by SOC rule SOC166 detecting JavaScript code embedded in the requested URL. Device action was 'Allowed' — the malicious request was permitted to reach the server and was processed. This is a True Positive requiring immediate containment.

03 EVENT & TRAFFIC ANALYSIS

3.1 Full Event Details

The SIEM captured the complete HTTP transaction. Source IP **112.85.42.13** (external Internet) sent a **GET** request to **172.16.17.17** on port **443 (HTTPS)**. The event was logged at 06:56 PM on Feb 26, 2022.

Event	
source_port	49183
destination_address	172.16.17.17
destination_port	443
time	Feb, 26, 2022, 06:34 PM
Raw Log	
Request URL	https://172.16.17.17/
User-Agent	Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gec... 
Request Method	GET
Device Action	Permitted
HTTP Response Size:	1024
HTTP Response Status	200

Figure 2 — Full Event Details: Source/Destination, HTTP Method, User-Agent, Device Action

3.2 Raw Log — HTTP Request & Response

Inspection of the raw HTTP log confirms the request reached the server. The **HTTP Response Status 200 OK** and **HTTP Response Size 1024 bytes** are the two critical success indicators for a Reflected XSS attack.

Hostname: WebServer1002 Domain: letsdefend.local IP Address: 172.16.17.17 Bit Level: 64 OS: Windows Server 2019 Primary User: webadmin15 Client/Server: Client Last Login: Feb, 02, 2022, 03:40 PM	Containment: 
---	---

Figure 3 — Raw HTTP Log: Request URL, User-Agent, Device Action Permitted, HTTP 200 / 1024 bytes

3.3 Malicious Request URL

```
https://172.16.17.17/search/?q=<$script>javascript:$alert(1)</$script>
```

The attacker injected a JavaScript payload via the **q=** search parameter. This is a textbook Reflected XSS probe — confirming whether the application echoes unsanitised input before escalating to session theft. The outdated User-Agent (Firefox/40.1, Windows NT 6.1) is consistent with an automated scanning tool.

HTTP 200 + 1024-byte response body confirms the server processed and reflected the malicious script. Any victim whose browser loaded this URL would have executed the attacker's JavaScript. **CLASSIFICATION: ATTACK SUCCESSFUL.**

04 PLAYBOOK WALKTHROUGH

4.1 Collect Data

The first playbook step requires gathering contextual data about the IP addresses and devices involved. IP ownership, reputation, and hostname/user context for the destination host were all retrieved.



Figure 4 — Playbook: Collect Data — IP Ownership & Host Context

4.2 Examine HTTP Traffic

The HTTP traffic was reviewed for suspicious payloads including XSS, SQL Injection, Command Injection, and IDOR. All request fields were examined. The injected payload was identified in the q= query parameter, confirming a Reflected XSS attack.

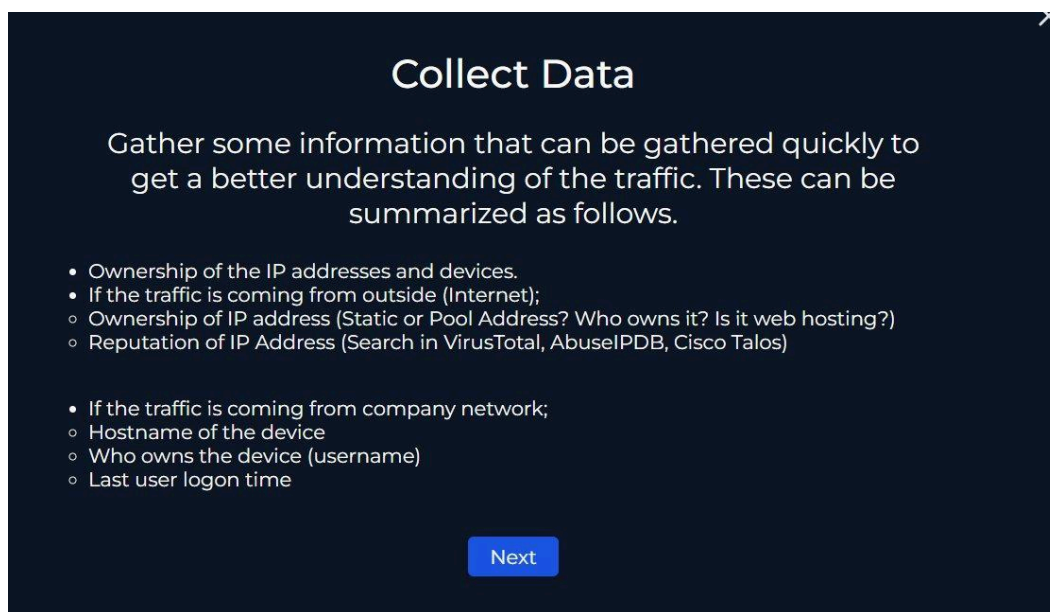


Figure 5 — Playbook: Examine HTTP Traffic — Web Attack Payload Detection

4.3 Check Whether the Attack Was Successful

Verdict: Attack was successful. HTTP Response Status **200 OK** and HTTP Response Size **1024 bytes** confirm the payload was reflected in the page content returned to the browser. A non-empty response body alongside HTTP 200 is the definitive success indicator for Reflected XSS.

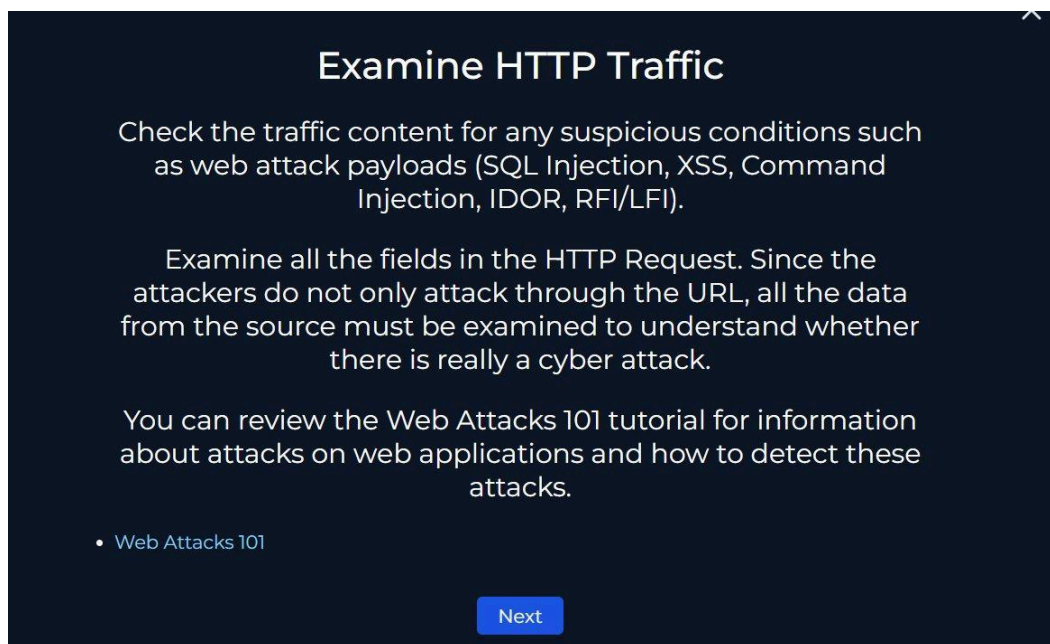


Figure 6 — Playbook: Check Whether Attack Was Successful — HTTP Response Indicators

HTTP Response Status 200 + Response Size 1024 bytes = XSS payload reflected and confirmed successful. Escalate to endpoint containment immediately.

05 SOURCE IP INTELLIGENCE

Threat intelligence lookups were performed on attacker IP **112.85.42.13** using WHOIS, MXToolbox, and reverse IP analysis to characterise the attacker's infrastructure and support blocking decisions.

Check Whether the Attack Was Successful

Investigate whether the attack was successful. Detection mechanisms vary according to the attack type. Some tips that can help with your investigation;

- In Command Injection attacks, you can understand whether the attack was successful by looking at the "Command History" of the relevant device via Endpoint Security. In SQL Injection attacks, attackers can run commands on the device with the help of functions such as "xp_cmdshell". For this reason, you may need to look at the "Command History" in SQL Injection attacks.
- You can guess by looking at the HTTP Response size in SQL Injection and IDOR attacks.

You can access the Web Attacks 101 training below, in which we explain how you can understand whether the attack is successful or not according to the attack type.

- [Web Attacks 101](#)

[Next](#)

Figure 7 — IP WHOIS Lookup: 112.85.42.13 — APNIC Asia Pacific Allocation

Source	Result	Assessment
WHOIS	APNIC — Asia PacificNet Range: 112.0.0.0/8	External, large regional pool — no specific org attribution
MXToolbox	No records returned	No mail infrastructure associated with this IP
Reverse IP/DNS	No PTR record found	No domain associated — unattributed or dynamic IP
Reputation	No threat intel flags at time of investigation	Absence of listing does not indicate benign use

No reverse DNS, no MX records, no domain association. Consistent with a dynamically assigned or VPN/proxy IP used to obscure attacker identity. Absence of threat intel flags does not indicate the IP is benign.

06 TRAFFIC DIRECTION ASSESSMENT

Traffic direction was confirmed as **Internet — Company Network**. External IP 112.85.42.13 initiated the request targeting internal server 172.16.17.17. This is inbound attack traffic from outside the perimeter — no lateral movement or internal threat actor activity was identified.



Figure 8 — Playbook: Traffic Direction — Internet to Company Network Selected

Traffic direction: Internet to Company Network. The attack originated entirely from outside the organisation's perimeter. Classification confirmed as inbound external web attack.

07 TARGETED HOST & ENDPOINT CONTAINMENT

7.1 Host Details

Hostname	WebServer1002
Domain	letsdefend.local
IP Address	172.16.17.17
OS	Windows Server 2019 (64-bit)
Primary User	webadmin15
Client/Server	Client
Last Login	Feb 02, 2022, 03:40 PM
Containment	HOST CONTAINED — Endpoint Security isolation active

7.2 Endpoint — Pre-Containment State

The Endpoint Security module was checked for WebServer1002. Prior to containment the host was online and reachable with no active isolation. Host details confirmed: Windows Server 2019, primary user webadmin15.

Containment

Since it is detected that the device is compromised, the device must be isolated in order to restrict the attacker, prevent the spread of the attack and reduce the impact.

Go to the Endpoint Security page and contain the relevant device with the help of the "Request Containment" button.

- Endpoint Security

****** Each institution has a separate containment procedure. While some institutions give containment authorization, some do not. Do not forget to learn the containment procedure in the institution you work for.

Next

Figure 9 — Endpoint Security: WebServer1002 — Host Details, Containment Not Yet Active

7.3 Containment Action Taken

Upon confirming the attack as a True Positive, **WebServer1002** was immediately contained via the Endpoint Security module to isolate the host, prevent lateral movement, and preserve evidence integrity pending full remediation.

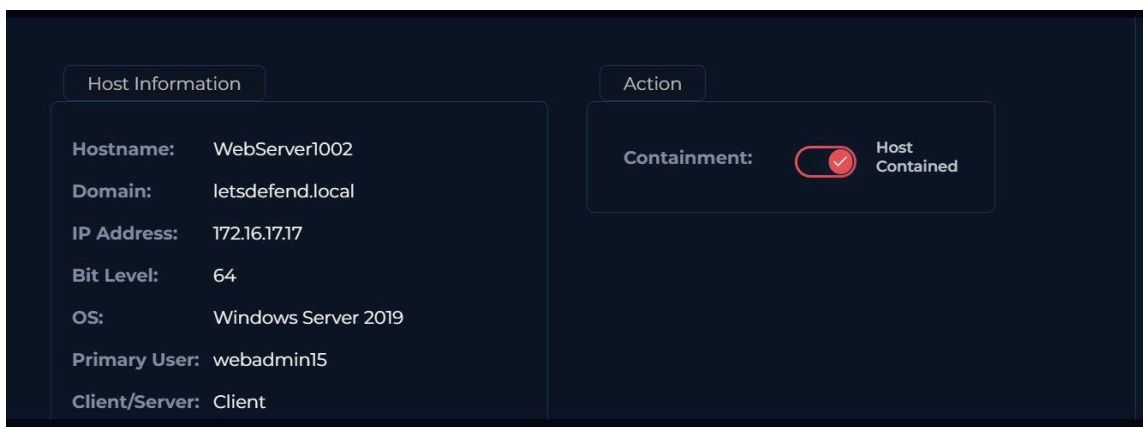


Figure 10 — Endpoint Security: WebServer1002 — Host Successfully Contained

All five playbook stages completed: Data Collection — HTTP Traffic Examination — Attack Success Verification — Traffic Direction Assessment — Endpoint Containment. Host remains isolated pending full remediation and security audit.

08 MITRE ATT&CK® MAPPING

ID	Name	Tactic	Evidence	Detection
----	------	--------	----------	-----------

T1190	Exploit Public-Facing Application	Initial Access	GET /search/?q=<script>javascript:alert(1)</script> — HTTP 200 confirms exploitation	Alert on script tags in URL params. Deploy WAF with XSS ruleset.
T1059.007	JavaScript	Execution	javascript:alert(1) via q= parameter reflected in HTTP 200 response body	Deploy CSP headers. Block inline script execution.
T1027	Obfuscated Files or Info	Defense Evasion	\$script\$ variant probes for WAF filter bypass opportunities	Content-aware WAF: decode/normalise before inspecting.

09 INDICATORS OF COMPROMISE

Type	Value	Context	Action
IP	112.85.42.13	Attacker source — APNIC Asia Pacific	Block at perimeter firewall & WAF
IP	172.16.17.17	Victim — WebServer1002 (internal)	Remediate before releasing from containment
URL	/search/?q=<script>...	Confirmed XSS attack endpoint	WAF blocklist pattern rule
Payload	javascript:alert(1)	XSS probe injected via q= parameter	WAF rule: block javascript: URI in params
Host	WebServer1002	Compromised internal web server	Full security audit required
User	webadmin15	Primary user of compromised host	Force credential reset

10 RECOMMENDATIONS

#	Priority	Action
1	HIGH	Implement strict input validation and output encoding on the /search/ endpoint. Encode all user-supplied data before reflecting it in HTML responses — this is the root cause fix.
2	HIGH	Deploy a Content Security Policy (CSP) header: Content-Security-Policy: default-src 'self'; script-src 'self'. Prevents inline script execution even if injection occurs.
3	HIGH	Block source IP 112.85.42.13 at the perimeter firewall and WAF immediately.
4	MEDIUM	Review all web application logs on WebServer1002 for additional XSS attempts, payload variants, or reconnaissance from this source IP.
5	MEDIUM	Deploy WAF rules to detect and block XSS payloads including <script> tags, javascript: URI schemes, and event handler variants (onerror, onload).
6	MEDIUM	Conduct a full web application security audit (DAST/SAST) on WebServer1002 before releasing from containment.
7	LOW	Notify webadmin15 and application owners. Require mandatory credential reset for all accounts with access to WebServer1002.
8	LOW	Close as CONFIRMED TRUE POSITIVE. Update SIEM/SOAR status. Retain all evidence and this report for future threat intelligence correlation.

11 RISK ASSESSMENT

11.1 Likelihood x Impact

Likelihood	HIGH — Attack was executed and confirmed successful. HTTP 200 + 1024-byte response confirms full reflection.
Technical Impact	HIGH — XSS payload reflected in HTTP response. Would execute in any victim's browser loading the URL.
Business Impact	MEDIUM — Session hijacking and credential theft risk. No confirmed data exfiltration at this stage.
Overall Risk	HIGH — Successful web attack on internal server. Immediate patching and input sanitisation required.

11.2 CIA Impact Assessment

CIA Pillar	Impact	Basis
Confidentiality	Medium	A victim who executed the XSS payload could have session tokens or credentials stolen by the attacker via the reflected script.
Integrity	Low	No server-side files or data modified. No evidence of persistent defacement or data alteration.
Availability	Low	No denial-of-service component. WebServer1002 was contained as a precaution, not because of service disruption.

12 LESSONS LEARNED

#	Area	Lesson
1	Input Validation	User-supplied data in URL parameters was reflected into the HTTP response without sanitisation. Output encoding is the critical control — input validation alone is insufficient to prevent XSS.
2	WAF / Perimeter	No WAF rule blocked the inbound XSS payload despite a clear <script> tag in the URL. WAF rulesets must cover JavaScript URI schemes, script tags, event handlers, and encoding variants.
3	Content Security Policy	The absence of a CSP header meant no browser-side control prevented script execution. CSP is mandatory for any publicly accessible web application.
4	Detect vs Block Gap	Device action was 'Allowed' — detection without prevention extends attacker dwell time. Convert detect-only rules to block rules where risk is confirmed.
5	Containment Playbook	Pre-defined containment thresholds (e.g. HTTP 200 + XSS payload = auto-contain) reduce analyst decision latency. Codify these triggers in the SOC playbook.

Report prepared by:	Mehenni May	Platform:	LetsDefend SOC Platform
Case ID:	SOC166 — EventID 116	Report Date:	26 February 2022
Classification:	TLP:WHITE	Verdict:	TRUE POSITIVE — XSS Attack Confirmed

